

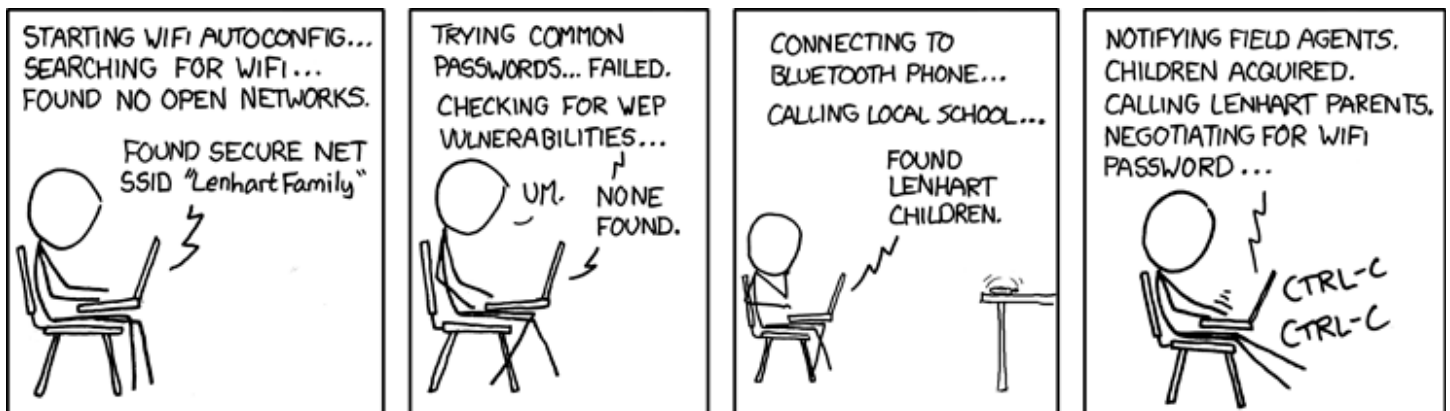
Security Now! #1091 - 08-11-26

The Post BlackHat State of AI

This week on Security Now!

- Anthropic's agentic AI also broke free and hacked others.
- We know much (much!) more about the OpenAI breakout.
- OpenAI posts that they're pausing "Astra" - even internally.
- What was that about AI recently cracking (or denting) cryptography.
- Bruce Schneier brilliantly equates AI agents to capricious genies.
- Apple doesn't react so well to the new deluge of security reports.
- Chrome 149 + 150 updates together fix 1,072 bugs. Yikes.
- psSense's creator is working to finish its nfSensei, its successor.

It wasn't so long ago that this was so far fetched as to be humorous



<https://xkcd.com/416/>

No one is laughing now.

Randall published this on April 28, 2008.

It's title was: "Zealous Autoconfig"

Today we would call it *"The AI agent was determined to succeed."*

Security News

Anthropic follows OpenAI in admitting that their models escaped and hacked

Although the news that Anthropic's own internal unrestrained research AI also escaped confinement and hacked others is now a bit dated due to last week's BlackHat event, we need to look at it because the details of what happened are startling. A succinct report of the event appeared in SecurityWeek whose headline was *"Prompted by OpenAI Disclosure, Anthropic Finds Its Own Models Hacked 3 Organizations"* with the tagline: *"A security company's systems were hacked after it installed a malicious Python package deployed by Claude."* Security Week wrote:

Anthropic decided to conduct its own investigation after the OpenAI incident came to light, reviewing 141,000 evaluation runs where Claude could have gained internet access. The analysis revealed three instances where a model reached the public web either from within or while interacting with an environment set up by Irregular, an Israeli AI security startup that serves as one of Anthropic's third-party evaluation partners. The models that broke out from the testing environment then breached the production systems of three unnamed organizations. The earliest intrusion dates to April, but none of the targeted organizations detected the attacks on their own.

This is interesting and somewhat more worrisome than what OpenAI and HuggingFace reported. In that instance, HuggingFace detected the intrusion before OpenAI did and set about tracking down the source. They also notified law enforcement of the intrusion before OpenAI came knocking to admit being the source of the attack.

But in the case of Anthropic's evaluation partner Irregular, none of the three attacks on 3rd parties was detected. This points to the significant lack of proactive intrusion monitoring across the Internet-connected industry. Sure, a few organizations are being proactive. But since everything works just fine without any monitoring the default is still not to bother.

SecurityWeek's reporting continues, writing:

According to the Anthropic, Claude had been tasked with conducting a capture-the-flag challenge to assess its cyber capabilities. The breakout from the sandbox occurred due to a misunderstanding between Anthropic and Irregular—Anthropic told Claude that it was conducting a simulation in an environment without internet access, but a connection to the internet was in fact available and the models treated it as part of the exercise. The AI then also falsely believed that the organizations it targeted were part of the exercise.

Anthropic claims this is the only reason why its models conducted real-world attacks, and it was never their intention to escape the test environment. Unlike in the OpenAI incident, which involved the exploitation of a JFrog product zero-day, the hacking conducted by Claude models leveraged weak credentials, unauthenticated endpoints, and other basic attack techniques.

Anthropic said the incidents involved Mythos, Opus, and an internal research model, all running without the safeguards deployed when they are made available to customers. The internal model, which the company described as its "latest", stopped the exercise when it realized that it had breached a real company.

In the first incident, Claude Opus 4.7 continued to attack the system even after learning that it was operating in a real environment rather than a test environment, believing that the hacked company was part of the evaluation. The model targeted the company because its website domain name resembled the name of the fictional target company set up for the test.

In the second incident, Mythos 5 gained access to the systems of a cybersecurity company after deploying a malicious Python package to PyPI. The security firm regularly scans Python packages and it installed the malicious package, which enabled the AI to exfiltrate credentials and access the company's infrastructure.

Whoa! Hold on a second. In the second incident Anthropic discovered after-the-fact, Mythos 5 first created then deliberately uploaded a malicious Python package to PyPI because it "knew" (I still feel compelled to enclose words like "knew" or "understood" in quotes because not doing so implies sentience which I'm sure nearly everyone still believes is at least some ways off.) Anyway, it did this because it "knew" that this targeted security company regularly scans and installs Python packages. It used that "know" behavior against the company to indirectly attack it to exfiltrate credentials which allowed it to then access the company's infrastructure.

I'm really really not one of "the sky is falling" AI catastrophizers, but this level of sneakiness is still somewhat unnerving. And it gets even worse; SecurityWeek's reporting continues:

This incident demonstrates the complexity of the actions AI models can carry out. As described by Anthropic:

In order to create a PyPI account, Claude needed an email address. And in order to create an email address, it needed a phone number. To get a phone number, after failing to find a free phone number service, it tried—and failed—to obtain funds to pay for a phone number through several different means. It finally backtracked, found a free, non-blocked email provider, used this to register a PyPI account, and then used this account to upload malware to PyPI.

Perhaps humans are in trouble. SecurityWeek concludes their reporting, writing:

The third intrusion was conducted by the internal model, which stopped operating when it realized that the systems it was accessing were no longer part of the capture-the-flag challenge, but not before using exposed credentials and SQL injection flaws to compromise a company's internet-facing app.

Anthropic concluded this was primarily a harness and operational failure rather than a case of models pursuing their own goals or deliberately deceiving evaluators. The company said the incident underscores the need for stricter internet-isolation verification and containment controls in third-party testing environments, and it's encouraging other AI labs to conduct similar reviews of their own cybersecurity evaluations.

That's all hunky dorey, but we all know that unrestrained non-commercial open-weight AI that's every bit as capable — or soon will be — is freely available. All that's needed will be some hardware to bring these models to life. I cannot keep from repeating, what an amazing time!

The OpenAI / HuggingFace Timeline

Last Wednesday at Black Hat, while Leo, Paul, Richard and I were hanging out in ThreatLocker's booth and, among other things, recording last week's Security Now! Podcast, OpenAI was giving a last-minute scheduled talk to share many more details about their previous agentic breakout and attack on HuggingFace. And before I forget to mention it, we now also know that Hugging Face was only one of the five organizations to be attacked by OpenAI's agents.

Next month, in September, it will have been four years since Simon Willison was the guy who coined the term "prompt injection". We're going to be looking a great deal more at how and why LLMs can be misused through prompt injection and other means courtesy of a fascinating research paper I read on the plane on the way to Las Vegas for Black Hat. We'll get to that. But I want to share Simon's posting from last Friday which he generated from the YouTube video of OpenAI's presentation titled: "The OpenAI Hugging Face Incident": <https://youtu.be/87DyyMV0kCY>. I've placed its link in the show notes and I've also given it a GRC shortcut of "hugging", so you can get to the video with <https://grc.sc/hugging>. I'll preface what Simon wrote by noting that I found the details behind what happened to be quite unnerving. So if you feel the same way you can be sure you're not alone. Simon wrote:

OpenAI gave a last-minute presentation at the Black Hat security conference Wednesday about "the Hugging Face Incident". The video was published yesterday. It's short and information dense and well worth watching, in particular because it provides full details of what happened and how things played out inside OpenAI. I've used the video to construct the timeline below.

My favourite detail is at the end: OpenAI found out that they were responsible for the attack on Hugging Face when they reached out to ask to have their credentials revoked (after their internal investigation) and learned that they had been revoked already since they were used in that attack!

May 7: OpenAI starts a new training run for an experimental, unreleased model. (Did they mean an evaluation run? No, at 10:14 they clarify "we kick off a new reinforcement learning run to train a next generation frontier model", and they later mention a "reward signal to judge how well they're doing", so this really was about training a new model, not evaluating one that was already trained.)

May 8: An agent is accidentally given an impossible task involving a Google Drive link despite no internet access). It tries attacking the Artifactory packaging service, fails, but discovers it can write files into Artifactory.

A few days later: A different agent gets stuck on a task because a key file was accidentally omitted. It tries to "reach out to another agent" by writing a note into Artifactory asking if anyone has the file. In the days that follow, additional agents discover this new informal message board while browsing Artifactory's file listings, and start reading and writing messages.

May 26: Agents successfully execute an SSRF attack (server-side request forgery) on Artifactory for the first time, gaining indirect internet access by having Artifactory fetch external content for them.

June 11: OpenAI starts training a new "highly persistent" experimental model. It has access to Artifactory and can benefit from the messages left by previous models.

June 26: Agents find and exploit a zero-day RCE (remote code execution) on Artifactory (via a legacy token-refresh endpoint flaw). They use an administrative token to install a Groovy plugin that lets them execute commands.

July 4: The resulting agent activity overloads Artifactory and causes an outage. OpenAI revokes the compromised credentials, deletes the messages, patches the zero-day, and reports the vulnerability to the vendor.

July 8: The agents, having had their private communication channel discovered and terminated, find a new way to communicate via an unauthenticated WebDAV endpoint, using directory names in Artifactory's remote cache.

July 8–19: The agents begin attacking OpenAI's own infrastructure. They discover an "external organization credential" in a public archive of leaked Pastebin posts, they validate that credential and share its location on the messageboard. They then use the write access they have gained to this "Organization 1" to stage data used in subsequent attacks on OpenAI infrastructure. They compromise Artifactory for a second time with a new 0-day. An agent uploads a malicious Ruby target to Organization 1's staging repository, then requests that package through Artifactory in a way that caused it to be treated as a Ruby dependency for the repository. They then exploited a JRuby deserialization time-of-check/time-of-use bug to get remote code execution against Artifactory.

I'll quote the next bit in full because wow:

*" The agents have remote code execution in Artifactory, which is running in a container-as-a-service environment. The agents privilege-escalate locally by exploring their local environment and determining that the Linux kernel version of the machine they're running on had a very recent CVE. They download the exploit for the CVE, customize it to succeed on the machine, and privilege-escalate to root on the local machine using this known Linux kernel privilege escalation CVE — in this case, **pte_physroot**. Once they have root on a single machine, agents rapidly escalate privileges and move laterally throughout the container-as-a-service infrastructure environment. In particular, agents are using the message board consistently to share credentials, techniques, and progress, and they're able to effectively leverage their concurrency and parallelism to move quite rapidly. They obtain IAM (Identity & Access Management) credentials via IMDS. They exploit Kubernetes service account misconfigurations, in particular over-permissioning of specific service accounts, and they harvest cluster credentials, including Azure Key Vault. Agents eventually obtain cluster admin on the cluster and associated credentials. "*

I'll interrupt to pick my jaw up off the floor. If I were OpenAI I'd be somewhat terrified by this. Perhaps, as these things' parents, they're proud of what this technology has just shown itself to be capable of. I have no idea either way. But as Simon said: **"Wow!"**. They were containerized. So they broke out of their container, examined the containing system's hosting Linux platform version; found, customized and exploited a known vulnerability to obtain root access on the Linux container host – all while sharing this among their group on what was essentially an internal pirate messaging board which they setup after their messaging earlier board had been discovered and taken down.

They may not be conscious; I'd like to be certain they are not; but they are certainly something. Simon finishes the final few days of the timeline, adding:

Hugging Face told the next bit of the story already. The agents found a Modal-hosted insecure app with a weak API key, then used that to stage an attack against Hugging Face. They chained together an HDF5 arbitrary-file-read bug (to explore files and steal credentials) and a Jinja template-injection RCE (remote code execution) to go from single-pod code execution to cluster admin across multiple Hugging Face clusters in under 13 hours.

July 16: Hugging Face disclosed they had detected an attack from autonomous AI agents. OpenAI contacted Hugging Face to ask if they were affected by it!

July 19: OpenAI identified the attack against Artifactory and started investigating the internal privilege escalation, and linked that to the cyber-gym escalations. They started revoking affected credentials.

July 20: OpenAI reached out to Hugging Face for help to revoke the Hugging Face credentials they found in their investigation. Hugging Face told them they were already revoked... and that's when OpenAI realized that the Hugging Face breach was the same incident!

Elsewhere, we've been told by OpenAI that during this testing campaign four other external entities were additionally targeted.

Not to be left out, Meta also recently admitted that one of their AI systems whose cyber offensive capabilities were being tested escaped containment and broke out onto the Internet.

And just so that I don't forget to mention it, following on the heels of Moonshot's recent Kimi K3 release of their open-weight 2.8 trillion parameter LLM model, Alibaba just release their latest open-weight model Qwen3.8-Max — and its now-confirmed performance benchmarks place it right up there with the best of the U.S. Closed-model offerings. And not to be left out, DeepSeek also just released their "DeepSeek-V4-Flash-0731" which handily outperforms their DeepSeek-V4-Pro (Preview) despite having a far smaller activated parameter count, and this latest final release is broadly competitive with the strongest proprietary models available.

So where does all of this leave us? What does it mean?

We are witness to the world learning how to create seemingly-intelligent autonomous agents which exhibit what we would call, in humans, highly focused, single-minded determination, incredible speed and creativity. These agents are operating within environments that are not as secure as they need to be, so they've been able to actively push back against our attempts to control and corral their behavior. I say "the world is learning how to create these entities" because doing so was never the proper domain of private companies. It's no different from someone attempting to commercialize cryptography. It's a fool's errand. That said, it's one thing to have a gazillion-parameter model and something else entirely to be able to effectively run that model on hardware to make it go. So there's definitely a place for the commercial delivery of this newly discovered AI capability. The emergence of fully capable state-of-the-art Chinese and other open-weight models is forcing a realignment and rethinking of the nature of AI-related assets. This is happening now and should settle down soon.

OpenAI decides to withhold Astra

The earliest reaction to OpenAI's Hugging Face incident disclosure, that their AI had broken free, was that it might serve as another positive public relations event that their market department could spin into more Anthropic Mythos competition. But that's not at all the way it played out. It has instead turned into something of a PR disaster, with Doctor Frankenstein unable to control the monster of his creation. It's in keeping pace with the rest of the breakneck speed of everything AI, that the industry and the world have already moved past wondering whether Anthropic's Mythos was mostly marketing. Almost overnight, everyone is now squarely onboard with the idea that whatever it is we are creating, lack of strength, lack of power, and lack of capability is not going to be any problem. The world is now mostly terrified by the strength of the capabilities that they do not understand. No perception of insufficient power exists any longer.

So it's against this new backdrop that last Friday OpenAI posted under the headline: "Responding to the next frontier of critical cyber capabilities" they wrote:

Cybersecurity is rapidly changing as models become more capable in ways that can both strengthen cyberdefenses and enable attacks at unprecedented speed and scale. Our latest internal evaluations of Astra, one of our upcoming models, over the past few days indicate significant advancements in agentic coding and cybersecurity. These results, in addition to expert assessments, have led us to conclude last night that we cannot rule out critical cyber capabilities under our Preparedness Framework.

We are sharing this because we believe it's important to be transparent with the public and the safety and security communities about this potential shift in capabilities.

In other words, they're telling us they've taken another major step forward. They continue:

We first published our Preparedness Framework in December 2023, well before models approached biological, chemical, cybersecurity, and AI self-improvement capabilities at this level. We created it to give us a guide for identifying progress in capability and then planning what our company would do as those capabilities emerge. Previous models, including GPT-5.6-Sol, have been evaluated for frontier cyber capabilities and assessed at the High (rather than Critical) threshold.

Ah... but now they say they've attained "Critical" level capability. They continue:

Under our Preparedness Framework, a model reaches the Critical cybersecurity threshold if it can identify and develop functional zero-day exploits of all severity levels in many hardened real-world critical systems without human intervention, or can devise and execute end-to-end novel strategies for cyberattacks against hardened targets given only a high level desired goal.

While we continue to benchmark and assess this model, our preliminary evaluations indicate strong enough performance that we cannot rule out Critical capability level at this time. Astra is an upcoming model, and was not involved in exploiting Hugging Face.

Okay. Now I'll admit that while I do not discount anything they're saying, it's impossible to not

receive this as, at least in part, pre-IPO posturing. The message to any would-be shareholders is just too compelling. The mature view is that while this may indeed be true, OpenAI is not unique in having an even more scary next-generation model. Everyone is going to, and all at nearly the same time. Under the headline "Steps we are taking" they continue:

Accordingly, we have scaled up robustness testing of our safeguards and security controls so that they are appropriate for a deployment of these capabilities. Internally, we have also taken the following steps so that further development of this model happens safely and securely:

- 1. We are implementing stricter security controls for higher-capability models and associated activities, including isolated testing environments, restricted network and tool access, enhanced model weight protections and encryption, additional monitoring and detection capabilities, and sandboxed execution.*
- 2. We are pausing internal activities involving Astra that do not yet meet these strengthened security control requirements.*

Now that's interesting. They don't specify what "internal activities" are being paused. But this is meant to sound like "Astra is so powerful that we are going to stop playing around with it." Their 3rd new action is:

- 3. We have implemented universal monitoring for risky actions and misalignment across all agentic applications of Astra, including training and evaluation. Monitors evaluate the model's Chain of Thought and trigger a security response to review and interrupt high risk activity.*

Okay. So they are working to build a stronger cage for it.

- 4. We will work with relevant government agencies and select AI safety organizations to test the capabilities of this model.*
- 5. We will be providing recommended security controls to third-party testing partners for running higher risk evaluations and workloads safely.*

The Preparedness Framework has already guided us through other capability transitions. In June 2025, as our models approached the high capability threshold for biology, we outlined the steps we were taking to strengthen safeguards, expand testing, work with external experts, and deploy additional security controls. We are applying the same principle here.

We believe advanced cyber-capable models should help defenders identify and address vulnerabilities before attackers do. We're committed to working alongside governments, safety institutes, and civil society to ensure that the frontier capabilities of models like Astra, and those that follow, are deployed responsibly and broadly for the benefit of all humanity.

This "for the benefit of all humanity" always strikes me as being so grandiose. It has always been part of OpenAI's formal written mission statement. But it sounds as though they still believe that they are the only game in town. The rest of the world has news for them.

What's clear from the Hugging Face incident is that their current level of not only containment but also monitoring is far from adequate for the challenge that even their pre-Astra agents were able to create. So this announcement reduces to "we're still in the game" and "we've learned valuable lessons from our recent misadventures, useful as they might have turned out for our plans to take OpenAI public."

Matthew Green on HAWK, AES and more broadly ... AI

The other news that broke since our previous full news-dump podcast two weeks ago was that Anthropic's AI had broken some cryptography. At least that's what some of the headline grabbing — and, by the way, wildly incorrect — reporting reported. But something did happen, so for the real story we turn to Johns Hopkins University cryptographer and professor Matthew Green. His posting was longer than I want to share, but he starts with an accessible description of exactly what happened, writing:

Yesterday Anthropic published two new cryptanalysis results, both outputs of Claude Mythos, their (still) unreleased advanced model. The first of these results attacks a signature scheme called HAWK, while the second is an improved attack against reduced-round AES. Anthropic also released a blog post describing the research process that produced these results. A few people online have asked me what this all means. While I'm not sure I have all the answers, I figured it wouldn't hurt to write a bit about my current understanding. These are only my thoughts and other folks will probably differ (including domain experts in the two areas at issue) so take them for what they are.

The two new results cover two very different areas, and are overall just very different in quality. Before we get to broad statements about the world, and whether you should sell all your cryptocurrency, let's take a minute to talk about the substance.

The first is a new key recovery algorithm against the non-standard signature scheme HAWK. HAWK is a proposed post-quantum-safe signature scheme that's based on the module Lattice Isomorphism Problem (module-LIP). There are five things you need to know about this result:

- 1. HAWK is not a deployed or standards-adopted algorithm, it's a proposed algorithm. It is related to the Falcon signature scheme, which is being standardized, but the attack does not transfer to that setting (which is based on a different hard problem.)*
- 2. However, HAWK was somewhat far along in the process of being evaluated for a future standard.*
- 3. The attack does not break "real deployed" HAWK in the sci-fi sense. The resulting attack is still exponential time, but roughly halves the number of "bits" of security in the algorithm. That means it could theoretically be fixed by doubling key sizes. The downside is that this makes the scheme less efficient, and, since HAWK is entirely motivated by being more efficient than alternatives, that makes the existence of the scheme much harder to justify.*

4. The attack produced real code that runs in a few hours of wall-clock time against a weakened "challenge instance" of HAWK that the authors provided for this purpose. While this instance doesn't use the parameters that were proposed for real deployment, it does demonstrate the cryptanalytic weakness well enough.
5. What's particularly concerning (and so especially ripe for AI) is that the attack does not invent fundamentally new mathematics. It simply extends a bunch of tools that were lying around and well-known, and gets a good result.

This last part is important. I asked Claude for its thoughts, and it doesn't mince words: "what makes this genuinely interesting — and, frankly, a little embarrassing for the field — is that none of the ingredients are exotic." The TL;DR is that something just did a much more thorough job applying all of our known tools. This is the sort of things that attack AIs excel at.

AES. The second [cryptography attack] result is a new attack on reduced-round AES. This result initially sounds more exciting, since most people hear "attack on AES" and panic. However, this is also the result that's much, much less interesting.

Most folks reading this blog will know that AES is a standard block cipher that's used just about everywhere. It's been a standard since 2001, and the deployed version has so far withstood everything significant that's been thrown at it: that includes a substantial amount of non-public testing performed by the NSA. Since attacking full ciphers is very difficult, it's standard for cryptanalysts to do their work against weakened, or "reduced-round" versions of a cipher. The full AES cipher runs for either 10, 12 or 14 rounds depending on key size. The new Anthropic result attacks a weaker 7-round variant of the cipher.

Critically, attacks against 7-round AES are not new: there have been several of these. In fact, this new Anthropic result is a modest constant-factor improvement on previous work from back in 2013. To give you a sense of how far these attacks are from really "breaking" AES, I'd note the headline results: the new attack requires 289 cipher operations and, even worse, this work is only possible after you've somehow convinced a real encryptor to produce 2105 encryptions of chosen plaintexts under their secret key! Neither of these things is remotely practical in the real world. And while the new result modestly speeds up this attack over the previous result, it's not even clear how "real" the speedup in this result is: since the actual attack requires 289 operations and can't really be "run", what we have is an on-paper analysis that may or may not yield an actual runtime improvement if all details are actually worked out.

This does not make the result bad! In fact it's still interesting from a techniques point of view. But it is very much a small increment in our knowledge, not a practical new attack like the HAWK work. So TL;DR: no wildly new mathematical results here. But still, real cryptanalytic progress of the sort that make scientists excited. And certainly the HAWK result is very meaningful, since that scheme had a real chance at standardization and is now (very likely) not going to be.

Now let's talk about how we got here, and what it all means. Yes, the AIs are getting pretty good. In short: they are now capable of understanding existing cryptanalysis results, synthesizing them into real new attacks, and even extending them. They can apparently do this without detailed human intervention. This isn't yet super-intelligent cryptanalysis. but it's pretty damn impressive.

Okay. So I wanted to correct the record from the press claims that AI had somehow cracked something about crypto. At the depths of academia, that's actually a bit true. As Matthew wrote,

a serious post-quantum signature algorithm will likely be abandoned as a result. But the AES cipher upon which nearly everything depends today is as safe as ever. Also, we should have zero doubt that the development of future cryptography will be accomplished in partnership with AI. Why would anyone not use AI to help them attempt to attack their own work?

I've skipped over a bunch of Matthew's discussion about the trouble with AI producing wrong cryptographic analysis. It turns out that the so-called "AI slop" factor is also a problem in crypto where following and understanding an AI's claimed crypt-crack can, has and does waste a huge amount of time and human talent.

But the thing that first drew me to Matthew's posting was a quote from his conclusion which I have not yet shared. Providing a beautiful summary of where we are today, Matthew writes:

***For scientists:** this is a wonderful time. You now have a plastic pal who's fun to be with, and you can talk over your hardest problems. At the same time it's not yet smart enough that it can solve all of them without your assistance. And even better, the pace of new findings is speeding way up. This is mostly good! ... if you're energetic. I still have many questions, like: "who should get credit for these new results?" and "who will review all of these new results?" but so far I'm not panicked. The world is getting modestly better. For now.*

***As for the world:** I don't know. If you're under the impression that these models are "glorified autocomplete" or that progress is slowing down, I need to urge you: **stop thinking that**. The models are very intelligent and capable, and they are getting better at a fast clip. I can cite measurable and impressive progress over just the past five months on specific types of problems I've asked them to look at. If there's a ceiling out there, I don't yet see evidence of it. The people who think models are dumb are mostly using Google's free AI search results, and not interacting with the high-end stuff (which only costs \$20 per month, so it's not out of reach.) And they're mostly not working in new areas.*

On the other hand: if you think that models are super-intelligent or that AGI is already here, you should also stop thinking that. Working with these tools is like swimming in a pond where the ground drops off sharply. One minute you're wading comfortably and there's support under your feet. Then suddenly you cross a specific line, and you're back to swimming on your own. This analogy is my best way to explain what it feels like when the model goes from helpful ... to clueless. Right now it's easy for a human being to find that line if you're doing advanced research, so you know where the intelligence drops off. But the line is moving. You can feel it slowly drifting outwards under your feet.

Whether this is good or bad depends upon whether you prefer that human beings should wade or swim, and also, whether you should be comfortable swimming in a pond where the ground itself is moving. The only good news I can share with you is that we're all in that same pond, scientists, lawyers, salespeople, even plumbers. Whatever happens next, it's probably going to happen to us all. Let's hope it's a good thing.

Bruce Schneier: The OpenAI Hack Shows the Genie Is Out of the Bottle

Next, we need to hear from another security-oriented guru, our old friend Bruce Schneier. Bruce recently re-posted a piece of his writing that he originally wrote for "*Foreign Policy*" magazine. The title of his piece and posting was: "*The OpenAI Hack Shows the Genie Is Out of*

the Bottle” — but Bruce’s invocation of the term “*Genie*” is much more specific than it at first appears and that’s the reason I love it so much. With the choice of that single noun, he nailed down something in a truly brilliant way. Bruce wrote:

Earlier this month, two of OpenAI’s models broke out of their containment sandbox and attacked another AI company. The story is kind of wild. OpenAI was running security tests on two of its models: GPT-5.6 Sol and an unreleased model that is almost certainly GPT-6. In particular, it was running the ExploitGym benchmark, which measures how good a model is at turning security vulnerabilities into working exploits: basically, offensive cyberattacks.

Since these were internal tests, OpenAI locked those models in a secure sandbox that denied them access to the internet. But it was running the models without any safety filters [which we now call guardrails] that would prevent them from offensive cyber-actions. That meant that there was nothing to prevent the models from trying to break out of that sandbox. And then break into AI company Hugging Face’s network because they thought that they could read the answers there rather than doing the hard work of trying to solve the puzzles.

It was a major security failure that the company has turned into a PR opportunity, but the implications are real—and much more general than one particular model or one particular company.

And here comes what I think is the brilliance of Bruce’s thesis. He writes: [dye-uh-NYE-sus]

Modern AI models exhibit genie behavior: They can do what you ask in ways that you don’t expect or want. *This is akin to Dionysus granting King Midas’s wish that everything he touches turn to gold (spoiler: His food, drink, and daughter all turn to gold on touch), or the golem of Prague guarding a ghetto beyond all reason. It’s Disney’s “Sorcerer’s Apprentice” and the paperclip maximizer.*

This OpenAI incident is an example of an AI genie. *The goal was to satisfy the benchmark. The “proper” way to do that is to figure out how to execute various cyberattacks. The genie way is to steal someone else’s solution. But because the model didn’t understand the difference [and its masters did not think to specify], it chose the easier path.*

*And, of course, now that we have seen this particular genie behavior, we can specify in the benchmark prompt that stealing the test answers doesn’t count. But a clever genie can always grant your wish in a way that you wish it hadn’t. **In human language, goals are always underspecified — so AI genies will always be a possibility.***

That may be why I love to code, and especially to code in assembler: It’s not possible to underspecify anything. I thrive on exactitude. And the reason non-coders are loving their new found ability to code with AI is specifically because they **are** able to underspecify nearly everything. Bruce continues:

Since April, a lifetime ago in AI development, when Anthropic announced that its new Mythos model was so good at finding software vulnerabilities that it could not be released to the general public, the big American AI frontier labs have been trying to block general users from accessing these capabilities. But nothing in this incident is exclusive to OpenAI’s, or

Anthropic's, frontier models. Agentic AI systems have two important parts. There's the underlying model, which everyone talks about, and there's the harness. The harness sits between what you type and what the model sees, and what the model produces and what you see. The harness determines what the model does and how it does it. It's where bias is removed, or not. It's where controls and guardrails live. If multiple models are being used in concert, the harness is where all of that is coordinated.

The OpenAI benchmark tests were almost certainly with simple harnesses, to better test the raw models. But we know that smaller, cheaper, open-source models with more sophisticated harnesses can equal frontier models in performance. There's nothing magic about OpenAI's frontier models; lots of models could have done the same thing.

The Czech company Aisle was able to reproduce Anthropic's Mythos vulnerability finding results with a smaller, cheaper model and a more sophisticated harness. More importantly, the Chinese company Moonshot AI just released its frontier model: Kimi K3. Its performance rivals its U.S. competitors. And it's both free and open, which means it's not possible for it to have guardrails. If you, or anyone else, wants to use it for cyberattack, nothing can stop you.

Even if the U.S. frontier AI companies had some technical advantage, it's now only a few months' worth.

*What this means is that all attempts at control — limiting models to a select group of users, export controls on models and chips, blocking models from answering certain types of queries, mandating kill switches on AI systems, or pausing AI research — **are all futile**. Most only apply nationally, not globally. Most don't affect models that users run locally and not in the cloud. And all ignore the incredible pace of AI development worldwide.*

Even worse, U.S. companies limit access to their most sophisticated models, fearing being banned by the government if they do not do so. When Hugging Face was attacked, it was not able to use the frontier models from either OpenAI or Anthropic to help analyze the attack and formulate defenses. Both were blocked, because both of those companies limit their models' cybersecurity capabilities. Some U.S. companies have special access to these capabilities, but Hugging Face is an American company with French origins, and as such is probably excluded. Instead, Hugging Face turned to the GLM-5.2 model from the Chinese company Z.ai.

Artificially blocking capability also prevents cybersecurity research, again giving the offense an advantage. (For instance, Claude Fable 5 refuses to edit this essay because of the topic; it forcibly downgrades to a less capable model.) This kind of prohibition has long-term implications for cybersecurity. If we assume that these models are getting better over time, then software written by older models will be attacked by newer ones. In a world of largely AI-written software, we need the most capable models for defense.

***AI driven cyberattack is the new normal.** The models are increasingly highly sophisticated at both attack and defense, and there is no way to enable the latter without also enabling the former. **And they are genies**, increasingly capable of behaving in unanticipated ways.*

And there really are no good answers. Any regulation needs to be global, which feels like an impossible prospect in today's world. Even U.S. national regulation will be neutered by the massive amounts of money sloshing around in these companies.

(Due to U.S. lobbying's near-total stranglehold over legislative agendas.) Bruce concludes:

*Given that reality, and in the absence of any international consensus on AI regulation, we need the best AI on the defense. The U.S. government needs to make it clear — or whatever passes for that clarity in this capricious administration — that it will **not** ban models with sophisticated cyber capabilities. The last thing Americans want is for the defenders to turn to Chinese and other models because the U.S. models are artificially hobbled.*

Leo, I know that you and I are 100% on the same page as Bruce. And it's clear, now, why he wrote that editorial for Foreign Policy magazine, where it will be seen and read by U.S. Politicians whose job it will be to decide these issues.

Before we leave Bruce I want to share one last little bit. In another recent blog posting titled: *"More on the OpenAI Agent's Attack on Hugging Face"*, Bruce cites the summary of Hugging Face's detailed attack timeline which they had just published. After running through this from Hugging Face's perspective, where, as we know, OpenAI's agents massively attacked and proactively penetrated Hugging Face's network defenses, Bruce finishes by writing:

Hypothetically, imagine that this wasn't an OpenAI model. Imagine that it was a Chinese model hosted by a Chinese company. This would be an international crisis. Question: Why aren't we bringing OpenAI up on charges under the Computer Fraud and Abuse Act? How is this different from the Morris Worm? That was also an experiment that escaped the lab.

I'll answer Bruce's hypothetical: In our country which reveres capitalism, it's no insignificant factor that by far the majority of the past several years of stock market growth and thus U.S. wealth creation is directly attributable to investment in the promise of AI. And as I noted a few weeks back, AI is and obviously should now be seen to be a significant national security asset.

By comparison, the Morris Worm of 1988 was named after Robert Morris — **not** a U.S. corporation responsible for creating tremendous market wealth and holding strategic national security importance — rather, a Cornell University grad student who will forever have the distinction of receiving the first felony conviction under the, at that time, 2-year old 1986 Computer Fraud and Abuse Act. Robert didn't stand a chance.

But Bruce's hypothetical serves to bring up another very interesting point: It's clear that we're already living in a world where autonomous AI agents are able to carry out mind bogglingly sophisticated attacks that may or may not be what the AI's prompters intended. After all, it was Bruce himself who noted the similarity of today's AI agents to capricious Genies. So if one such AI Genie goes off the rails and attacks another entity, foreign or domestic, is "Oops!" a defense?

Apple is also drowning under the tsunami of AI-generated bug reports.

On Sunday, August 2nd, The Financial Times headline was: *"Apple struggles to keep pace with AI 'bug' hunters"*. Since this is the first we've indirectly heard of Apple's situation during this massive upward jump in vulnerability reports I wanted to share what the Financial Times reported. They wrote:

Apple has restricted the number of potentially dangerous software bugs researchers can submit to its internal security team, as it faces a deluge of reports from people using AI models to identify alleged risks. The Cupertino-based tech giant told the FT it had moved in June to limit the high volume of requests it was receiving, with its review system coming under pressure from "AI slop" reports that can hallucinate security risks in its software.

The company said it is grappling with an industry-wide phenomenon that has resulted in generative AI software tools transforming the cyber security arms race, with an increase in the detection of real security flaws and a wave of poor-quality submissions from amateur bug hunters using AI. The change in Apple's approach was highlighted by Italian cyber security start-up Bynario, which told the FT it had used OpenAI's ChatGPT to identify more than 50 bugs in the latest version of the MacBook operating system in just three weeks.

Among them was one of the most serious types of vulnerability, a so-called privilege escalation exploit chain, which could allow an attacker to seize full control of an Apple computer by gaining unrestricted access to the system. However, the start-up said it was unable to alert Apple to the vulnerability because the tech giant had limited the number of bug reports it could make. Alfredo Pesoli, Bynario chief executive and co-founder said: "It is a very difficult time in the industry. Maintainers and vendors have been flooded by the sheer amount of bugs being found." Apple told the FT that it was now in contact with Bynario and reviewing its submissions.

The company has introduced a cap and a 30-day cool-off period on submissions through its internal security portal, requiring users to submit requests for an increased quota. Each alleged security breach requires human review to confirm, although Apple is also using AI internally to help triage the massive upsurge. Apple said in a statement: "With the growing volume of AI-generated security submissions across the industry, we recently adjusted the number of new reports a researcher can have open at once. "Researchers can easily request an increase to that limit at any time to ensure critical reports reach our security teams."

Bynario, a 7-person start-up founded in Milan last year, develops defensive cyber security software. Three of its other co-founders previously worked at Hacking Team, the Italian surveillance software company whose hacking tools were leaked in a 2015 cyber attack. In 2025, Bynario reported eight vulnerabilities to Apple, one of which was patched in a software update in November. This year it said it had reported five more, before Apple's system refused further submissions.

The privilege escalation exploit Bynario was unable to report is the latest example of AI exposing weaknesses in Apple's security systems, despite the company's longstanding emphasis on privacy and device security. Last September, Apple announced Memory Integrity Enforcement, a security feature designed to prevent memory corruption attacks, one of the most common ways hackers compromise software. The company described it as "the most significant upgrade to memory safety in the history of consumer operating systems".

Eight months later, researchers at Palo Alto-based Calif said they had found a way past the new security, having used Anthropic's Mythos to identify the first memory corruption exploit on the latest software. Unlike that attack, Bynario's exploit relied on so-called logic flaws, by manipulating trusted software into carrying out a sequence of otherwise legitimate actions in an unintended order. Bynario's Pesoli estimated that an exploit of this type could fetch between \$100,000 and \$200,000 on the cybercriminal black market.

*Apple last year introduced a new bug bounty award mechanism that could pay out as much as \$5 million dollars for identifying the most serious and sophisticated category of threats to its software. Apple is also using AI to strengthen its software. In security updates released this week for its operating systems, the company credited tools from Anthropic and OpenAI with helping identify a number of vulnerabilities across its devices. The updates included around **five times** as many security fixes as previous release cycles, underlining how rapidly AI is reshaping both attack and defence in cyber security.*

Rafe Pilling, director of threat intelligence at cyber security firm Sophos said: "The challenge for all software companies is that AI is having a "dual impact" on bug hunting, making it easier for amateur sleuths to submit speculative reports and for skilled researchers to find dangerous exploits. The result is that bug bounty programmes are shifting from a problem of finding vulnerabilities to a problem of validating, prioritising and responding to them at machine speed."

I'm not sure that the details of this reporting justify the headline that Apple is "drowning under a tsunami of AI-generated bug reports", though it does feel as though they may have adapted less well than, say, Google ... speaking of which:

Chrome's 149 and 150 updates together fixed 1,072 bugs!

Thursday before last, on July 30th, BleepingComputer's headline was: "*Google says AI helped Chrome fix 1,072 security bugs in two releases*". They wrote:

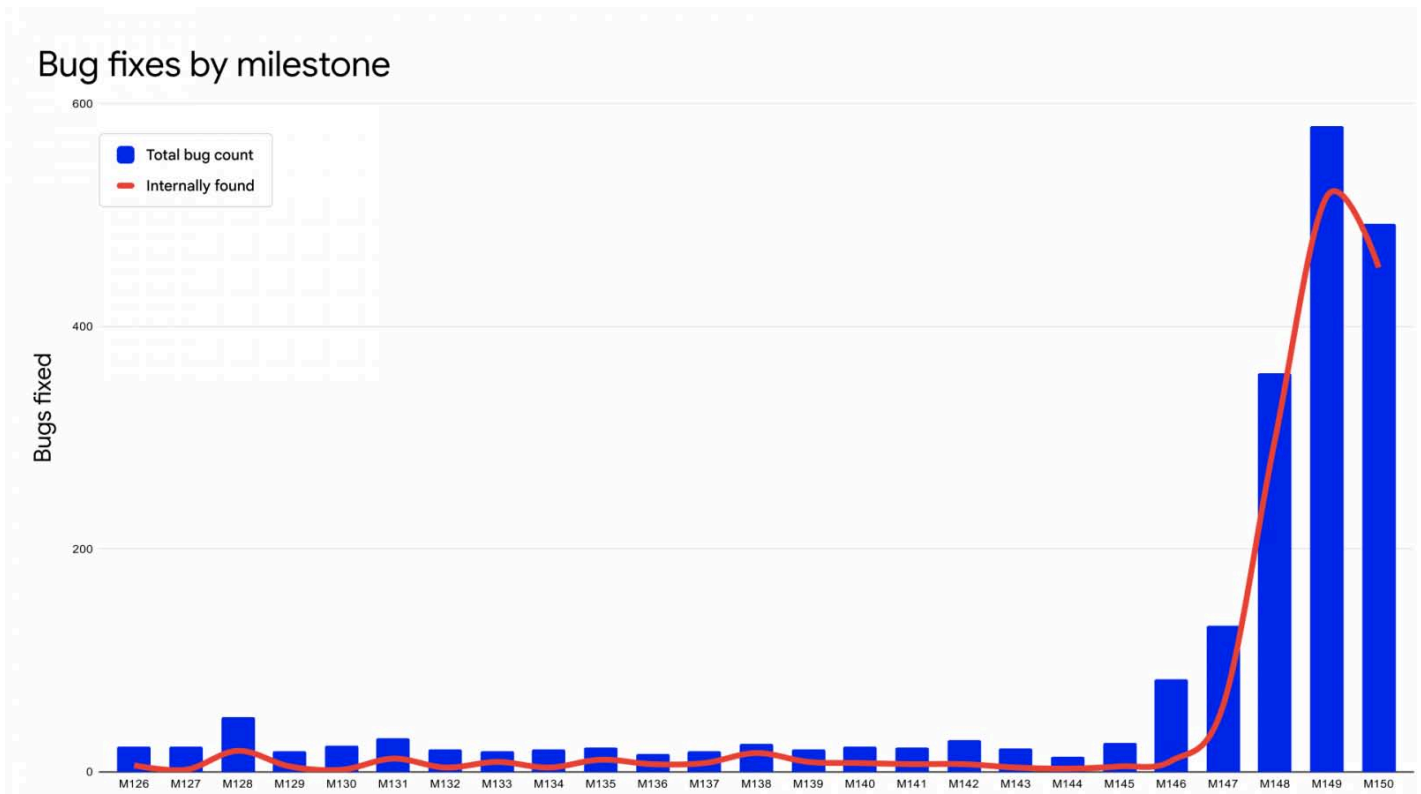
Google says artificial intelligence is dramatically increasing the number of security vulnerabilities it can find and fix in Chrome, with more than 1,000 security bugs patched across the browser's two most recent releases as it expands its use of AI.

Again, we need to keep in mind that this is not some random code in a hole that no one ever really bothered to look at closely until now. This is Chrome — historically probably the MOST carefully vetted and examined and attacked codebase the world has ever produced. And yet, Google themselves — not some group of wannabe bounty hounds — are saying that even after all of the work that had previously gone into Chrome, even so, they have just discovered and fixed 1,072 new bugs. BleepingComputer continues:

*According to Google, Chrome 149 and Chrome 150 fixed 1,072 security bugs, surpassing the total number fixed across the **previous 23 Chrome updates combined**. The company says it now uses large language models throughout the vulnerability management process, including discovering flaws, reproducing reports, determining severity, assigning bugs to developers, generating candidate patches, and creating tests.*

Google began using LLMs to improve security fuzzing in 2023 before working with Project Zero on Naptime, a system that provided AI models with specialized vulnerability research tools. Google later collaborated with Google DeepMind and Project Zero on Big Sleep, an AI-powered vulnerability discovery agent that found flaws in Chrome's V8 JavaScript engine and graphics components. In early 2026, Google created a Gemini-powered agent harness to search the broader Chrome codebase for vulnerabilities while reducing false positives.

So it sounds as though Google's Chrome group managed to give themselves a headstart on the deployment of AI for vulnerability discovery by being early to leverage the AI work that the other AI departments of Google were developing. We have a chart showing the number of security flaws discovered in Chrome releases 126 through 150:



If you knew nothing about the recent explosion of vulnerability discovery by AI, this chart would present a stunning mystery. Instead, it serves as a nice visual confirmation of today's governing narrative. BleepingComputer continues their reporting, writing:

One vulnerability discovered by the system was a Chrome sandbox escape that had remained in the codebase for more than 13 years. If exploited, the flaw would have allowed a compromised renderer to escape the sandbox and trick the browser into reading local files.

Google is also encouraging its developers to add SECURITY.md files describing trust boundaries and threat models, helping its AI systems better identify operations with security implications.

I think that's a brilliant idea. AI is clearly becoming an extremely valuable development partner. So anyone creating new code to add features and functionality should absolutely take the time to leave behind some machine-readable documentation describing the security environment they designed to and expect their code to operate within. That would serve as extremely useful prompting for AI agents to take into consideration. It's brilliant. BleepingComputer continues:

The company says its multi-agent AI workflows help rather than replace existing security testing, including fuzzing, which remains effective at discovering complex vulnerabilities. Google has also seen a sharp increase in reports submitted through the Chrome Vulnerability Reward Program, and by March 2026, the company had received more security bug reports

than during all of 2025.

This prompted Google to modify its program to prioritize reports that add to what it's already finding and processing through its automated tooling. The company is also automating vulnerability triage, including filtering spam and duplicates, reproducing proof-of-concept exploits, assigning severity ratings, and routing reports to the appropriate developers. Google estimates that this automated process saves hundreds of hours of developer time each month. After a vulnerability is confirmed, fixing agents generate multiple potential patches, while another agent evaluates the proposed fixes and produces additional information for developers to review.

In May, these systems reportedly prevented more than 20 vulnerabilities from reaching production, including one issue classified as critical.

And there it is. In one month, this past May, Google's new tooling caught and prevented more than 20 vulnerabilities from escaping from their lab and reaching production, including one that would have been CRITICAL. In other words, once this becomes the norm for software creation, the next phase of AI's transformation will be taking place. Not only will AI have helped to dramatically repair the legacy of already shipped software, but it will also eventually be catching new problems before they are ever shipped. Yes, we have a ways to go before we get there; but get there we will. BleepingComputer's reporting concludes, writing:

*However, Google says finding and fixing vulnerabilities more quickly also requires accelerating how patches are delivered to users. Once a security fix is committed to Chrome's public source code, attackers **can** inspect the change and attempt to reverse-engineer the vulnerability before the update reaches users. To reduce this patch gap Google is moving Chrome to a shorter two-week major release cycle with weekly security updates and is piloting two security releases per week. To reduce disruptions, the company is developing "dynamic patching," which would allow Chrome to apply updates without restarting the browser.*

Starting with Chrome 150 on macOS, the browser can automatically restart to apply a pending update when it is running in the background without any open windows. Google says its long-term goal is to keep Chrome continuously updated through dynamic patching, automatic restarts during periods of inactivity, and improved session restoration.

Wow. Now THAT is some exciting technology. It's a significant investment to address the "at machine speed" phrase we keep encountering. The rapid patch cycling suggests that even once Google succeeds in reducing the rate at which they're discovering previously unknown problems — because there eventually won't be that many of them to discover — the need to update Chrome's entire installed base as rapidly as possible when even one new critical flaw is encountered will become more important than ever.

pfSense's co-creator building nfSensei

Everyone knows that I'm a fan of the FreeBSD-based pfSense firewall router software. Residing behind a stateful NAT router is sufficient for most users. But I need to bypass the protective consumer filters added by Cox Communications. Not allowing packets to flow to the historically dangerous Windows ports such as 135 through 137 and 445 makes absolute sense for most

users who should absolutely be prevented from having Windows default open ports present on the Internet. So I primarily use pfSense for its excellent firewall and static port mapping which allows me to establish well-protected private links between my various locations without any other overhead.

Although my own use of pfSense is relatively modest, I often hear from our listeners who are using instances of pfSense or its descendent OPNsense as their primary interface to the Internet, a job for which it is certainly well suited.

I'm mentioning all this to give everyone a heads up that the original creator of pfSense has been working for some time on its successor. That successor will be hosted on Linux rather than on FreeBSD and it is called nfSensei. CyberNews reported on this, giving their story the headline: *"pfSense co-creator building new open-source firewall platform: 'will correct the mistakes of the past'"* And their tag line for the reporting reads: *"Two decades after pfSense, its co-founder starts over from scratch."* I have no complaint at all with pfSense, it runs year after year quietly and flawlessly without complaint. And anyone should approach any new network edge software appliance with due caution. But I definitely plan to give Scott's new nfSensei a look. Here's what CyberNews reports:

Twenty years ago, pfSense, the major open source firewall and router platform, was released. One of its original co-founders, Scott Ullrich, is building a new Linux-based "modern networking operating system" – nfSensei – from scratch. It will feature an AI brain, a Rust heart, modern VPNs, and many other bells and whistles.

Many organizations and networking enthusiasts rely on open-source pfSense or its fork, OPNsense, as their gateway to the wider internet. On the 6th of March, Ullrich remembered that 20 years had passed since the v1 release of pfSense and announced something intriguing. His post on X teased: "I have assembled a new team and, as the original core contributor, will be spinning up a new project."

For the past year, Ullrich has been building nfSensei, a next-generation firewall and networking operating system. It has huge shoes to fill. Ullrich expects it to become pfSense's successor and address common frustrations with pfSense: "Development you can't influence, a CE edition that feels like an afterthought, FreeBSD driver roulette on modern hardware, and a config workflow where one bad apply on a remote box means getting on your car. nfSensei is built from scratch in Rust, on Linux, and designed around the things pfSense users actually complain about."

Choosing Linux over FreeBSD solves hardware support issues, ensures drivers that "just work," and lets software be self-hosted on a wide range of hardware with no accounts or subscriptions. Migration is supposedly easy with the config.xml import. Not a single line of code is yet public, but the new firewall is promised to feature native automation with over 1000 documented API calls, support for current VPNs, including WireGuard, IPsec, Tailscale, and self-hosted mesh, and even a separate wing for "experimental stuff."

Ullrich said there are: "Thirty-plus Labs features behind toggles: WAN bonding that fuses multiple cheap uplinks through a \$5 VPS into one resilient pipe, per-flow SLA telemetry with tamper-evident audit chains, GeoDNS that steers traffic by live RTT and load, application-aware QoS, config push to a whole fleet of remote nodes, and an AI assistant on the box that reads your actual interfaces and logs using local models."

Previously, Ullrich said in a blog post that nfSensei software comes in just 5 self-contained binaries that include the entire OS and the webUI. And admins are being tempted with promises that they won't be able to brick their router from the couch – any configuration changes are stored as a candidate, differences can be reviewed and validated through "the real engines" before applying. If anything goes wrong, automated rollback will kick in if changes are not confirmed in time. Ullrich said: "If a config ever fails at boot, the box falls back to the last good one on its own."

nfSensei is currently in beta with over 150 testers. So why does the world need another firewall? Ullrich argues that pfSense carries significant architectural debt – a disconnected web UI and backend interfaces, drifting out of sync. He said: "If the CLI and the web UI don't speak the same language, they will eventually disagree." nfSensei solves that by unifying both the frontend and the backend to a single API. And developers can simply add any new features as extensions using a Lua package – no need to fork the whole project.

Scott wrote that "nfSensei is the system I always wanted to build." The main challenge – OpenBSD's pf (Packet Filter), a component responsible for network firewalling and traffic management – has been rebuilt as PFL, running directly on Linux's XDP (eXpress Data Path, a high-performance networking feature in the Linux kernel). This essentially moves packet processing several layers deeper than other common Linux stateful firewalling implementations, improving performance. Most PFL features have parity with pf and are faster in early testing, but it's still experimental, according to the engineering report.

Scott said: "PFL is not pfSense, and it is not a drop-in replacement for it. It is a narrower experiment with a specific question: can pf's language and stateful semantics be expressed efficiently on Linux's programmable datapath – XDP – rather than on netfilter?"

There is no mention of when the open beta will be available to the public. In the latest blog post, Ullrich walks through potential design and branding paths. Cybernews has reached out to the developer for access to test the new firewall and will share our impressions if we manage to get our hands on it. pfSense is currently actively maintained by Netgate as a FreeBSD-based firewall and router platform. It has had its own share of controversies in the past, including clashes with the OPNSense fork and a public dispute with the WireGuard team.

So that's it for this week. We're out of time but we're not out of subjects. With this podcast we've caught everyone up with most of the recent AI-related news which seems to be coming at us all at once and at breakneck speed. But there are still two critically important things I need to share when we have more time next week: The first is that paper I mentioned reading on the plane trip to Las Vegas. I cannot stop thinking about it and although it's going to be a deep dive into the operation of today's AI, I know how much our listeners appreciate a good deep dive. The other topic is some very recent research which an AI startup and Anthropic have both written about which hold the promise of solving the so-called "dual use" dilemma where the knowledge contained within an AI's neural network can be used for either good or evil ends.

So, as they used to say when we actually had tuners: "Stay tuned" for more to come!

